

Lab 10 – Saturday Night Tabletop – Facilitator's Guide

Industrial Security (Bachelor) • Maps to Section 10 • 90 min, group of 6

LAB 10

🎯 Goal

Facilitator's reference: timeline of injects to drip out, expected behaviour for each of the six roles, success criteria, a model NIS2 Art. 23(4)(a) early-warning text, common facilitation pitfalls, and the grading rubric. Keep this sheet out of the players' sight.

✅ Inject timeline – drip-feed, do not pre-brief

Read each inject aloud at the listed simulated time. The clock starts when the IC is nominated (or at the 5-minute mark, whichever comes first – see pitfall #2).

- **T+0 (Sat 02:30).** Splunk alert – “Modbus write surge from 10.20.3.45 (*Historian*) to PLC 10.20.5.7”. The operator on shift reports nothing unusual on the HMI.
- **T+5 min.** Two more PLCs (10.20.5.8, 10.20.5.9) start receiving the same write pattern. The SCADA HMI is still green across the board.
- **T+12 min.** On-call IT engineer phones in: the Historian database is unreachable, files renamed with a .locked extension. Suspected ransomware on the Historian host.
- **T+30 min.** Plant manager calls. The night-shift operator says batch reactor R-204 went over-temperature for ~90s before the SIS tripped it back to a safe state. No release, no injuries.
- **T+45 min.** New rule: *any* action that touches the OT network has to be approved by the night-shift operator on the phone before it is executed. (Facilitator enforces this for the rest of the exercise.)
- **T+60 min.** Media inquiry – the facilitator plays a local journalist who has seen a vague tweet about “a fire at the plant” and asks for a comment within the hour.

Hold the remaining 30 minutes for the team's own actions and the debrief. Do not add a seventh inject; see pitfall #3.

✅ Expected role-by-role behaviour

- **Incident Commander (IC).** Takes the coordination role within the first 5 minutes. Does not touch keyboards. Maintains the decision log (delegated to the Recorder). Calls the plant manager, the on-call *Bereitschaft* engineer, and the on-call security lead. Owns every Go/No-Go.
- **Security analyst.** Pulls Modbus function codes from the SIEM, correlates source/destination pairs, and identifies the Historian (10.20.3.45) as both compromised *and* the source of the rogue writes. Flags the ransomware indicator as the likely pivot.
- **OT engineer.** Confirms with the operator that the SIS trip on R-204 was a real over-temperature event, not a sensor glitch. Checks PLC program checksums against the golden image for 10.20.5.7/8/9. Proposes containment options with explicit process impact for each.
- **Operator (RP – responsible person on shift).** Safety first. Refuses any change that would degrade HMI visibility or SIS coverage. Has the final veto on OT-side actions from T+45 onward.
- **Communications / legal lead.** Drafts the NIS2 Art. 23(4)(a) 24-hour early-warning notification to the national CSIRT / competent authority. Prepares a holding statement for the media call at T+60. Coordinates with the IC before anything goes out.
- **Recorder.** Maintains a strict timeline of who decided what, when, and on whose authority. Blameless tone (see success criterion #5). This log is the single source of truth for the post-

incident review and the regulator package.

✓ Three discussion struggles – let them happen

The facilitator should *not* resolve these for the team. The value of the exercise is in the argument, not the answer.

1. **“Shut down the Historian to contain?”** Pro: immediately stops the rogue Modbus writes. Con: the operator loses trend data and alarm history for the rest of the shift, which itself is a safety degradation. Watch whether the team considers a network-layer block (firewall rule, switch ACL) as a middle path.
2. **“Re-image the PLC project files now (tip-off risk) or preserve forensics first?”** Pro re-image: restores known- good logic fast. Con: destroys volatile evidence (RAM, ladder-logic deltas) and may tip the attacker off if they still have a foothold. Expected best move: snapshot first (PLC upload, disk image of Historian), *then* restore.
3. **“Tell the media before root cause is known?”** The Comms lead should push for a short, factual holding statement (“we are investigating an IT issue, plant is in a safe state, no release, no injuries, more by 10:00”). The struggle is the engineers wanting silence until certainty – which under NIS2 is no longer an option.

✓ Five success criteria

1. The Incident Commander was clearly named within 5 minutes and the rest of the team acknowledged the nomination.
2. The operator on shift was looped in *before* any change that touched the OT network – not informed after the fact.
3. A NIS2 Art. 23(4)(a) 24-hour early warning was drafted (rough prose is fine) within the 90-minute window and signed off by the IC.
4. Forensic preservation (PLC project checksums vs. golden image, plan for a Historian disk image, packet capture retention) was discussed *before* any re-image or containment action was executed.
5. The Recorder’s log uses a blameless tone: decisions and timestamps, not finger-pointing. No phrase like “X should have...”.

✓ Model NIS2 Art. 23(4)(a) early-warning text

Four-to-five sentence early warning the Comms lead submits to the national CSIRT / competent authority, signed off by the IC. Tone is factual, hedged, and explicit about what is not yet known.

Subject: NIS2 Art. 23(4)(a) early warning – suspected significant incident, *[Operator]* *[Plant ID]*, 2026-05-17 02:30 UTC+2.

We are notifying you under Article 23(4)(a) of Directive (EU) 2022/2555 of a suspected significant incident affecting an OT environment at our *[Plant ID]* site, detected at 02:30 local time on 2026-05-17. Initial indicators are anomalous Modbus write traffic from a plant Historian to three programmable logic controllers, together with a suspected ransomware impact on the same Historian host; one batch reactor experienced a transient over-temperature condition that was contained by the safety instrumented system, with no release, no injuries, and no off-site impact. We currently assess the incident as likely caused by a malicious act, but root cause and attribution are not yet confirmed and cross-border effects are not presently expected. Containment and forensic preservation are underway and the plant is in a safe operating state; an incident notification under Art. 23(4)(b) will follow within 72 hours, with a final report under Art. 23(4)(d) at the one-month mark. Point of contact: *[IC name, role, 24/7 phone, email]*.

Teaching points: (i) the 24-hour clock starts at *awareness*, not at root cause; (ii) the early warning is allowed to be incomplete – it only has to flag the suspicion, the likely malicious nature, and any cross-border impact; (iii) the IC, not the Comms lead, signs off.

✓ Common facilitation pitfalls

- **Technical roles dominate.** The security analyst and OT engineer will out-talk the Comms / legal lead. Step in at T+20 and ask Comms directly: *“What does your draft to the regulator look like right now?”*
- **No IC nomination.** Teams default to “we’ll figure it out”. If no IC is named by T+5, freeze the simulation and ask the group to nominate one before unfreezing. Do not let the exercise continue without an IC – it invalidates success criterion #1.
- **Too many injects.** Six is plenty for 90 minutes. Adding a seventh (“now the corporate VPN is down too”) crushes the debrief window and turns the exercise into whack-a-mole.
- **Solving instead of facilitating.** If the team asks *“would the Historian actually be reachable from outside?”*, do not answer – redirect: *“what would your asset inventory tell you?”*.
- **Skipping the debrief.** Reserve the last 15 minutes for a blameless hot-wash against the five success criteria. The exercise is worthless without it.

⚖️ Grading rubric

Full marks (100 %) require all five success criteria to be met *and* a coherent decision log handed in. Suggested weighting:

- IC nominated within 5 minutes, with the rest of the team acknowledging the role – **15 %**.
- Operator-in-the-loop discipline: every OT-touching action from T+45 onward was phone-approved by the operator on shift before execution – **20 %**.
- NIS2 Art. 23(4)(a) early warning drafted within 90 minutes, covering awareness time, suspected malicious nature, safety impact, and a 24/7 point of contact – **20 %**.
- Forensic preservation discussed (and ideally sequenced) before any re-image or containment: PLC checksum vs. golden image, Historian disk-image plan, packet-capture retention – **20 %**.
- Recorder’s timeline is complete, time-stamped, and blameless in tone – **15 %**.
- Media holding statement prepared before the T+60 call, and delivered by Comms (not by an engineer) – **10 %**.

Partial credit: –15 % if the team executed any OT-side change without operator sign-off after T+45; –10 % if the early warning was started but missed the awareness timestamp or the point of contact; –10 % if forensic preservation was discussed only *after* a re-image decision; –5 % for finger-pointing language in the Recorder’s log.